AVERIX TECHNOLOGIES

PVT. LTD.

CYBERSECURITY RISK ASSESSMENT

HR Management Software as a Service (Saas)

Prepared By:

Averix Security Assessment Team

Date: November 2026

Document Version: 1.0

Confidentiality: Portfolio Project – Fictional Company

Executive Summary

Averix Technologies Pvt. Ltd is a fictional organization with 50 employees, offering IT services. The main offering from the company is a SaaS based Human Resource Management System. Their system handles sensitive data concerning employee details, employee attendance, payroll and recruiting.

This report aims to identify the potential risks Averix Technologies face with their HRMS platform, looking at the following areas: HRMS, Employee Database, Payroll, User Accounts, Backup, Source Code Repository and Email.

The Risk Based approach has been used throughout this report, looking at potential threats to these areas. Also looking at the vulnerabilities that may be present, the likelihood of these situations occurring and how they would affect the business. ISO/IEC 27001:2022 and NIST Cybersecurity Framework (CSF) 2.0 have been used as frameworks to help with the report.

Some of the main risks looked at are un-authorized access to employee data, data tampering, phishing, malware, disruption to the service and poor backup solutions. This could lead to issues concerning confidentiality, integrity and availability of the data, as well as losing customer confidence.

This report should create a risk register with prioritized risks and recommendations to treat them so that Averix Technologies can improve their cybersecurity.

Note: This is a fictional portfolio assessment based around assumptions made in the project. This is not a real organization audit or testing.

Business Context

1. Company Background

Averix Technologies Pvt. Ltd. is a fictional Information Technology company based in India. It has around 50 and develops and provides a Software as a Service (SaaS)-based Human Resource Management System (HRMS) for small and medium-sized businesses.

1.2 Business Operations

The company's HRMS helps customers manage their workforce through a range of functions, including employee information management, attendance tracking, leave management, payroll processing, recruitment and user account administration. These services support day-by-day HR activities of its customers

1.3 Technology Environment

To deliver and maintain its SaaS product, the company uses several supporting systems. These include the HRMS application, employee database, payroll module, user accounts, backup systems, source code repository and company email system. Together, these systems support the company's daily operations and product delivery.

1.4 Business Security Objectives

The main security objectives the company have are:

Confidentiality – To protect employee and payroll information from unauthorized access.

Integrity – To prevent unauthorized modification of employee, attendance and payroll records.

Availability – Maintain easy access to the HRMS platform for customers.

Access Control – Ensure users can only access the information and function required for their respective job roles.

Recovery – To recover business information and services for the following data loss or system disruption

Assessment Scope

2.1 Purpose of Assessment

This assessment is intended to identify and evaluate potential security risks to Averix Technologies Pvt. Ltd.'s SaaS-based HR Management System and its supporting systems. The assessment is designed to protect sensitive information and to ensure the confidentiality, integrity and availability of the services offered.

2.2 Systems Included in the assessment

The following systems and components are included within the assessment scope:

1. **HRMS Application:** The main application used by customers to manage HR activities.
2. **Employee Database:** Stores employee details and related information.
3. **Payroll Module:** Handles salary details and payroll records.
4. **Employee Accounts:** User accounts, roles and access permissions.
5. **Backup Systems:** Systems and processes used to retain and restore company data.
6. **Source code repository:** Stores the application's source code and development related files.
7. **Email System:** Used for internal communication and business activities.

2.3 Areas Excluded from Assessment

The following areas are outside the scope of this assessment:

1. Physical security of the company's office premises.
2. Customer owned computers and networks.
3. Detailed financial audits.
4. Full legal and regulatory compliance audits.
5. Independent penetration testing of external vendors.

2.4 Assessment Boundaries

This assessment focuses on potential risks related to information confidentiality, data integrity, system availability, access management and recovery. It is based on fictional company details and defined project assumptions. It does not include actual system testing, independent security verification or a formal certification audit.

Asset Inventory

3.1 Identifying the Asset

Asset identification is a critical element of the cybersecurity risk assessment process. It helps identify which systems, applications and information are critical for the company's operations and needs to be protected.

For Averix Technologies, the asset inventory centers on the systems that support its SaaS-based HR Management System. Each asset is identified based on its business purpose, the information it handles and its importance to the organization.

Asset Id	Asset Name	Purpose	Importance
A01	HRMS Application	Provides HR services to customers.	High
A02	Employee Database	Stores employee details and records	High
A03	Payroll Module	Manages salary and payroll information.	High
A04	User Accounts	Controls user access and permissions	High
A05	Backup Systems	Retains copies of business data for recovery.	High
A06	Source code Repository	Stores application source code.	High
A07	Email System	Supports internal business communication.	Medium

Threat Identification

4.1 Introduction

Threat identification involves recognizing potential events or activities that could harm an organization's systems, information and business operations. For Averix Technologies, the assessment considers threats that could affect its SaaS-based HR Management System and supporting business assets.

4.2 Identified Cybersecurity Threats

The following threats are considered relevant to the company's business environment:

Threat ID	Threat	Affected Asset	Potential Impact
T01	Phishing attacks	Employee Accounts, Email System	Stolen login credentials and unauthorized access.
T02	Malware or ransomware	HRMS Application, Employee Database	Data loss, encryption and service disruption.
T03	Unauthorized access	Employee Database, Payroll Module	Exposure of sensitive employee and salary information.
T04	Data manipulation	Payroll Module, Employee Database	Unauthorized changes to employee or salary records.
T05	Service disruption	HRMS Application	Customers may be unable to access HR services.
T06	Data loss	Employee Database, Backup Systems	Loss of important business information.
T07	Source code compromise	Source Code Repository	Unauthorized access to or modification of application code.

4.3 Summary

The detected threats may impact confidentiality, integrity and availability of the company’s information and services. These threats will be incorporated into the next round of vulnerability and risk assessment activities to assess potential impact on business

Vulnerability Assessment

5.1 Introduction

A vulnerability is a weakness in a system, process or security practice that could be exploited by a threat. This section identifies potential vulnerabilities affecting Averix Technologies' SaaS-based HRMS and supporting systems.

5.2 Identified Potential Vulnerabilities

The following vulnerabilities are assumed for this fictional assessment exercise. They have not been confirmed through actual technical testing.

Vulnerability ID	Potential Vulnerability	Related Asset	Potential Impact
V01	Insufficient employee awareness of phishing attack	Email System, User Accounts	Employees may disclose login credentials.
V02	Weak password practices	User Accounts	Unauthorized access to user accounts.
V03	Inadequate access permissions	Employee Database, Payroll Module	Users may access information beyond their job responsibilities.
V04	Delayed software updates	HRMS Application	Known software weaknesses may remain unaddressed.
V05	Inadequate backup verification	Backup Systems	Data recovery may fail when required.
V06	Insufficient source code access restrictions	Source Code Repository	Unauthorized users may access or modify application code.
V07	Lack of regular security monitoring	HRMS Application, Email System	Suspicious activities may go undetected.

5.3 Summary

The identified potential vulnerabilities may increase the likelihood or impact of cybersecurity threats. They will be considered in the next stage of risk assessment.

Risk Assessment Methodology

6.1 Introduction

Risk assessment is the process of evaluating potential cybersecurity risks based on their likelihood of occurring and the impact they could have on business operations. For this assessment, a 5 × 5 risk matrix is used to calculate and prioritize risks affecting Averix Technologies Pvt. Ltd.

6.2 Risk Scoring Methodology

Risks are identified using two factors
1. Likelihood: The possibility of a threat exploiting a vulnerability.
2. Impact: The potential damage to the company's information, systems or business operation

The risk is calculated using a formula:

Risk Score = Likelihood * Impact

Both factors are rated on a scale of 1 to 5. A higher score indicates a greater level of risk

6.3 Likelihood and Impact Scales

Score	Likelihood	Impact
1	Rare	Insignificant
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost Certain	Severe

6.4 Risk Rating Classification

The calculated risk score is classified into four levels:

Risk- Score	Risk Level
1-4	Low
5-9	Medium
10-16	High
17-25	Critical

6.5 Risk Assessment Matrix

Risk score = Likelihood * Impact

Likelihood↓ /Impact→	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

Low: 1-4 Medium: 5-9 High: 10-16 Critical: 17-25

6.6 Risk Evaluation

The risk matrix will be used to determine the priority of each identified risk. Risks with higher scores will receive greater attention when developing treatment recommendations. This approach provides a consistent basis for comparing and prioritizing cybersecurity risks.

Risk Register

7.1 Introduction

A risk register is used to record and prioritize cybersecurity risks identified during assessment. It connects business assets with relevant threats and vulnerabilities and evaluates their potential impact on Averic Technologies.

7.2 Identified and evaluated Risks

The following table presents the potential risks considered in this fictional assessment. Likelihood and impact scores are assigned using the methodology explained in Section 6.

Risk Register Table

Risk ID	Asset	Threat	Vulnerability
R01	Employee Database	Unauthorized access	Inadequate access permissions
R02	User Accounts	Phishing attacks	Insufficient phishing awareness
R03	Payroll Module	Data manipulation	Inadequate access permissions
R04	HRMS Application	Malware or ransomware	Delayed software updates
R05	Backup Systems	Data loss	Inadequate backup verification
R06	Source Code Repository	Source code compromise	Insufficient access restrictions
R07	Email System	Phishing attacks	Weak password practices

7.3 Risk Scoring and Evaluation

Each identified risk is evaluated using the likelihood and impact scales defined in the Section 6. The risk score is calculated by multiplying the likelihood score by the impact score.

Risk ID	Likelihood	Impact	Risk Score	Risk Level
R01	4	5	20	Critical
R02	4	4	16	High
R03	3	5	15	High
R04	3	5	15	High
R05	3	4	12	High
R06	3	5	15	High
R07	4	4	16	High

These are illustrative risk ratings based on fictional project assumptions, not measured or verified findings

Risk Treatment Plan

8.1 Introduction

Risk Assessment involves selecting appropriate actions to address identified cybersecurity risks. Based on the risk assessment we can implement security measures to reduce the likelihood and impact potential threats affecting its Saas-based HRMS and supporting systems.

8.2 Recommended Risk Treatment Measures

The following measures are proposed to address the risks identified in the risk register.

Risk ID	Identified Risk	Recommended Security Measures
R01	Unauthorized access to employee data	Implement role-based access control and regular permission reviews
R02	Phishing attacks	Conduct employee security awareness training and enable MFA
R03	Payroll data manipulation	Restrict payroll permission and maintain records of changes
R04	Malware or ransomware	Apply software updates regularly and use appropriate malware protection
R05	Data Loss	Maintain regular backups and periodically test data restoration
R06	Source code compromise	Restrict repository access and review codes changes
R07	Email account compromise	Enforce strong password and enable multi-factor authentication

8.3 Expected Outcome

Implementing these measures can help reduce cybersecurity risks, protect sensitive data and improve the security and reliability of HRMS platform. The effectiveness should me measured periodically

Framework Mapping

9.1 Introduction

Cybersecurity frameworks provide structured guidance for managing information security risks. This assessment uses ISO/IEC 27001 and the NIST Cybersecurity Framework (CSF) 2.0 As a reference frameworks to relate the proposed security measures to recognized cybersecurity practices.

9.2 ISO/IEC 27001 and NIST CSF 2.0 Mapping

The following table highlights selected ISO 27001 Annex A controls and relevant NIST CSF 2.0 functions and categories related to the recommendations in this assessment.

Security Area	ISO/IEC 27001 Annex A	NIST CSF 2.0
Access Control	5.15- Access control; 5.18- Access rights	Protect (PR. AA)
Security Awareness	6.3- Information security awareness, education and training	Protect (PR. AT)
Software Updates	8.8- Management of technical vulnerabilities	Protect (PR. PS)
Data Backup	8.13- Information backup	Protect (PR. DS)
Source Code Protection	8.4- Access to source code	Protect (PR. AA)
Security Monitoring	8.15- Logging; 8.16- Monitoring activities	Detect (DE. CM)

9.3 Framework Relevance

ISO/IEC 27001 provides requirements for establishing and maintaining an Information Security Management Systems (ISMS), along with Annex A reference controls.

NIST CSF 2.0 organizes cybersecurity risk management activities into six functions: Govern, Identify, Protect, Detect, Respond and Recover.

These frameworks help organizes the security recommendations and provide a structured reference for improving the protection of Averix Technologies SaaS based HRMS.

Note: *This mapping is for educational purpose. It does not demonstrate ISO27001 certification, conformity or a completed framework implementation.*

Conclusion

This cybersecurity risk assessment provided an overview of the potential security risks affecting Averix Technologies Pvt. Ltd. and its SaaS-based Human Resource Management System (HRMS).

The assessment identified seven important business assets and considered potential threats and vulnerabilities that could affect the company's systems and information. Using a likelihood and impact-based risk assessment approach, seven risks were evaluated and prioritized, including one Critical risk and six High risks.

Recommended security measures include implementing access controls, strengthening authentication, conducting employee security awareness training, applying regular software updates, maintaining reliable backups and restricting access to source code.

The assessment also demonstrated how ISO/IEC 27001:2022 and NIST Cybersecurity Framework (CSF) 2.0 can be used as reference frameworks when organizing cybersecurity risk management activities.

Overall, addressing the identified risks through appropriate security measures and regular reviews can help Averix Technologies protect sensitive employee information, maintain the reliability of its HRMS platform and strengthen its cybersecurity practices.

Note: *This report is a fictional portfolio assessment based on defined assumptions. It does not represent an actual security audit, technical testing or certification.*